Security Policies

Lecture 8, Information Security, 7,5 ECTS

Björn Praestegaard Larsen
bjorn.larsen@ju.se

Overview

- What is a policy?
- Understand the various policies and the rationale for them
- Know what elements go into good policies
- Evaluate and improve existing policies
- Security plan
- Incident response
- Information security management
- ISMS practice
- Physical security

Introduction

- The traditional view of information security is techno-centric
  - (more math than humans)
- More system administrators, less business process owners
- More buy a firewall, less understand where the risks are
- More proactive and strategic than reactive
  - (e.g., Plan, Do, Check and Act Model/continual improvement)

What is a policy?

- A security policy is a document that defines how an organization deals with some aspect of security.
- There can be policies regarding end user behavior, IT response to incidents, or policies for specific issues and incidents.

What is a policy?

- Policies are steering documents
- Policies can contain policies
- Policies can contains guidelines
- Policies can define objectives
- Policies can define goals
- Policies can identify weaknesses
- Policies helps to fullfill obligations

Defining User Policies

- Passwords
- Internet use
- E-mail attachments
- Installing/uninstalling software
- Instant messaging
- Desktop configuration

Management vs. Adminstration

- Information security is the highest management, not only the administration
- More information, more assets, higher value on assets, business-critical information systems…
- At the same time… more security skilled staff, more risks, better techniques, algorithms… we should be ok, but are not, why?

Example : Bring Your Own Device (BYOD)

- CYOD: The company lists acceptable devices (that is, those that meet company security requirements) and allows each employee to choose his or her own device.

- COPE: The company owns and provides the equipment. This clearly offers the most security, but also comes at the highest cost.

- CYOD-COPE stands for either company-owned and provided equipment or company-owned and personally enabled.

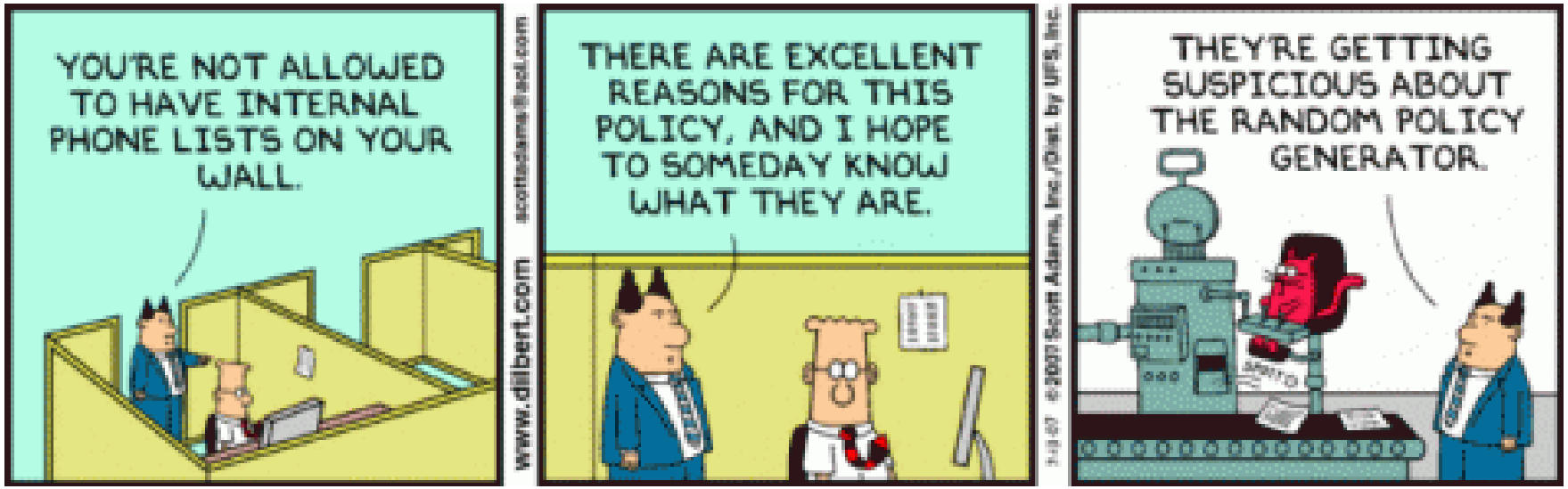
System Admin Policies

- New Employees
- Departing Employees
- Change Control
- Access Control

Information Security Policy

- Policy for Data security
  - Guidelines for Information security
  - Guidelines for Physical Security
  - Guidelines for Technical Security
  - Guidelines for Storage and Protection
  - Guidelines for Information Classification
- Policy for Incident management and response
  - Guidelines for notification to authorities
  - Guidelines for notification to the registered
- Policy for Roles and Responsibilities
  - Guidelines for data protection roles
- Policy for Work Environment
  - Guidelines for risk assessment
  - Guidelines for investigation of ill health, accidents, and incidents
  - Guidelines for fixing risks
  - Guidelines for employee exercise and wellness
- Policy for Competence Development
  - Guidelines for competence assessment
  - Guidelines for GDPR 2016/679 (EP/EC, 2016) competence requirements plan
- Policy for Processor Agreements
  - Guidelines for subjects and duration of processing
  - Guidelines for responsibilities and rights
  - Guidelines for processing
- Policy for Supplier Evaluation
  - Guidelines for supplier audit
- Policy for Information Technology
  - Guidelines for Information Technology
  - Guidelines for Intellectual Property Protection
  - Guidelines for Data Encryption
- Policy for Communication
  - Guidelines for internal communication
  - Guidelines for public relation and external media
- Policy for Mapping Personal Data
  - Guidelines for Personal Information Register
  - Guidelines for Personal Data Processing Register
  - Guidelines for Personal Data Flow Register
- Policy for Evaluation of Legitimate Interest
  - Guidelines for purpose test
  - Guidelines for necessity test
  - Guidelines for balancing test
- Policy for Privacy and Personal Data Protection
  - Guidelines for Privacy Messages
  - Guidelines for Personal Data Requests
  - Guidelines for Personal Data Incident Response
  - Guidelines for Personal Data Incident Information
- Policy for International Transfers of Personal Information
  - Guidelines for Risk Assessment
  - Guidelines for Masking Data
- Policy for Impact Assessment
  - Guidelines for identifying need and context
  - Guidelines for identifying, analysing, and classifying risks
- Policy for Employment Procedures
  - Guidelines for strong background check for new hires.
  - Guidelines for pre-employment agreements
  - Guidelines for the separation process for outgoing employees.
- Policy for Accounting systems
  - Guidelines for income-expense procedures
  - Guidelines for tax-reporting and documentation

Policies must have a purpose

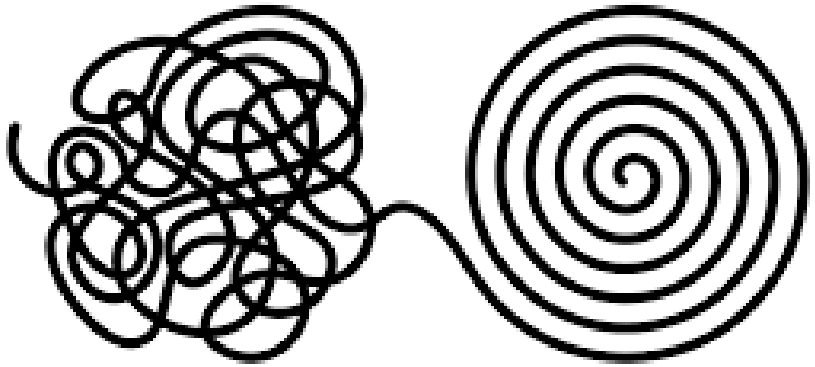


Introduction

- So many questions…
  - What data/assets do we possess?
  - Who has access to the data/assets? Why?
  - What are our assets worth? (Information classification)?
  - What legal, regulatory requirements affect us? In what way?
  - What about employee competence and security awareness?
  - What risks are there?
  - What if there is a breach?
  - What about disaster recovery?

Introduction

We need a systematic approach
for the
implementation of information security!



The 10 deadly sins of information security management

Not realizing …

1. that information security is a corporate governance responsibility (the buck stops right at the top)
2. that information security is a business issue and not a technical issue
3. that information security governance is a multi-dimensional discipline (information security governance is a complex issue, and there is no silver bullet or single 'off the shelf' solution)
4. Not realizing that an information security plan must be based on identified risks
5. the important role of international best practices for information security management
6. that a corporate information security policy is absolutely essential
7. that information security compliance enforcement and monitoring is absolutely essential
8. that a proper information security governance structure (organization) is absolutely essential
9. the core importance of information security awareness amongst users
10. Not empowering information security managers with the infrastructure, tools and supporting mechanisms to properly perform their responsibilities

Von Solms, B., & Von Solms, R. (2004!!!). The 10 deadly sins of information security management. Computers & Security, 23(5), 371-376.

Security plan

A security plan identifies and organizes the security activities for a system/organization

- Describes the current situation and highlights the improvement
- It is an official record of current security practices and a blueprint for orderly change to improve those practices

Security plan

- Content should include:
  - Security policy
  - Current security status
  - Security requirements
  - Recommended controls
  - Accountability/responsibility for implementation
  - Timetable
  - Plan maintenance

Explained in detail in the coming slides

Security policy

- Baskerville and Siponen (2002) divide policies into three levels:
  - (1) a high-level overall organizational policy,
  - (2) lower-level policies regulating selected information security methods, and
  - (3) a meta-policy describing how policies are created, implemented, and enforced.
- The security or information security policy is a high-level statement of purpose and intent
- Answers three essential questions:
  - Who should be allowed access?
  - To what system and organizational resources should access be allowed?
  - What types of access should each user be allowed for each resource?
- Should specify
  - The organization's security goals (e.g., define whether reliable service is a higher priority than preventing infiltration)
  - Where the responsibility for security lies (e.g., the security group or the user)
  - The organization's commitment to security (e.g., defines where the security group fits in the corporate structure)
- Should be "lagom" (not too long/complex/detailed/… and still meaningful/fast and easy to read…

Current security status

- Understand vulnerabilities
- Perform a risk analysis
  - A systemic investigation of the system, its environment, and what might go wrong
  - What assets do we have?
  - Forms the basis for describing the current security state
- Defines the limits of responsibility for security:
  - Which assets are to be protected?
  - Who is responsible for protecting them?
  - Who is excluded from responsibility?
  - Boundaries of responsibility?

Security requirements

- Security requirements are functional or performance demands placed on a system to ensure a desired level of security
- Usually derived from organizational business needs, sometimes including compliance with mandates imposed from outside, such as government standards

Characteristics of good security requirements

- Correctness
  - Are the requirements understandable? Are they stated without error?
- Consistency
  - Are there any conflicting or ambiguous requirements?
- Completeness
  - Are all possible situations addressed by the requirements?
- Realism
  - s it possible to implement what the requirements mandate?
- Need
  - Are the requirements unnecessarily restrictive?
- Verifiability
  - Can tests be written to demonstrate conclusively and objectively that the requirements have been met?
- Traceability
  - Can each requirement be traced to the functions and data related to it so that changes in a requirement can lead to easy reevaluation?

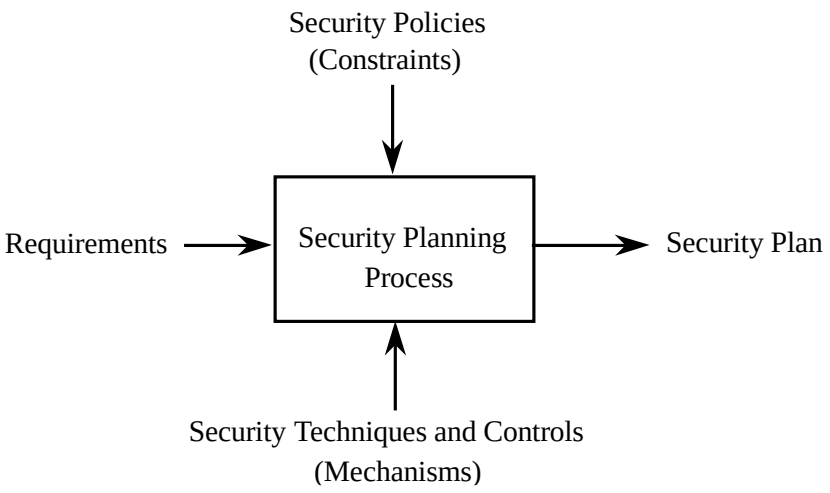
Accountability/responsibility for implementation

Part of the security plan will identify roles which are responsible for implementing security requirements

- Common roles:
  - Users
    - Regardless of if they are responsible for the security of their own machines, they have some responsibility
  - Owners
    - Product/process/system/…
  - Managers
    - May be responsible for seeing that the people they supervise implement security measures, and can also be legally responsible
  - Administrators
    - Network/system/security/database/…
  - Information officers
    - May be responsible for overseeing the creation and use of data; these officers may also be responsible for the retention and proper disposal of data
  - Personnel staff members
    - May be responsible for security involving employees, e.g., screening employees, handling terminations, arranging security training programs

Timetable and plan maintenance

- No instant implementation
  - A timetable of how and when the elements in it will be performed must be included
- The plan should specify the order in which controls are to be implemented
  - Start with the most serious exposures
- The plan must be extensible
  - New equipment will be acquired
  - New connectivity requested
  - New threats identified…
  - The plan must include procedures for change and growth
  - The plan must include a schedule for periodic review



Security planning team members and commitment

- Security planning touches every aspect of an organization and therefore requires participation well beyond the security group
- Common security planning representation
  - System administrators, developers, data entry personnel, physical security personnel, representative users, managers, (subcontractors)…
- A plan that has no organizational commitment collects dust on a shelf
- Three groups of people must contribute to making the plan a success:
  - Management
  - The planning team
  - Those affected by the security

Business continuity planning

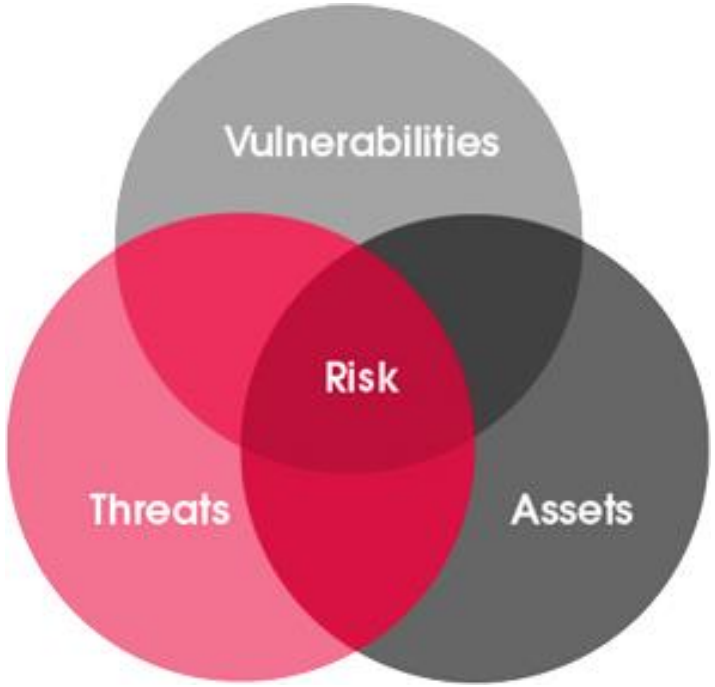
- A (business) continuity plan documents how a business will continue to function during or after a computer security incident
- Addresses situations having two characteristics:
  - Catastrophic situations, in which all or a major part of a computing capability is suddenly unavailable
  - Long duration, in which the outage is expected to last for so long that business will suffer
- Assess the business impact of a crisis
  - What are the essential assets?
  - What could disrupt the use of these assets?
- Develop a strategy to control the impact
  - Investigate how the key assets can be safeguarded
- Develop and implement a plan for the strategy, define:
  - Who is in charge when an incident occurs
  - What to do when an incident occurs
  - Who does what tasks when an incident occurs

Incident response

- A security incident response plan tells the staff how to deal with a security incident
- The goal of incident response is handling the current security incident without direct regard for the business issues
- An incident response plan should:
  - Define what constitutes an incident
  - Identify who is responsible for taking charge of the situation
  - Describe the plan of action
- The response team is charged with responding to the incident. It may include:
  - Director - the person in charge of the incident, who decides what actions to take
  - Technicians - people who perform the technical part of the response
  - Advisors - legal, human resources, or public relations staff members as appropriate
- Matters to consider when identifying a response team include:
  - Legal issues, preserving evidence, records, public relations…
- Larger organizations can use Computer Security Incident Response Teams (CSIRT), that are trained and authorized to handle security incidents

Risk

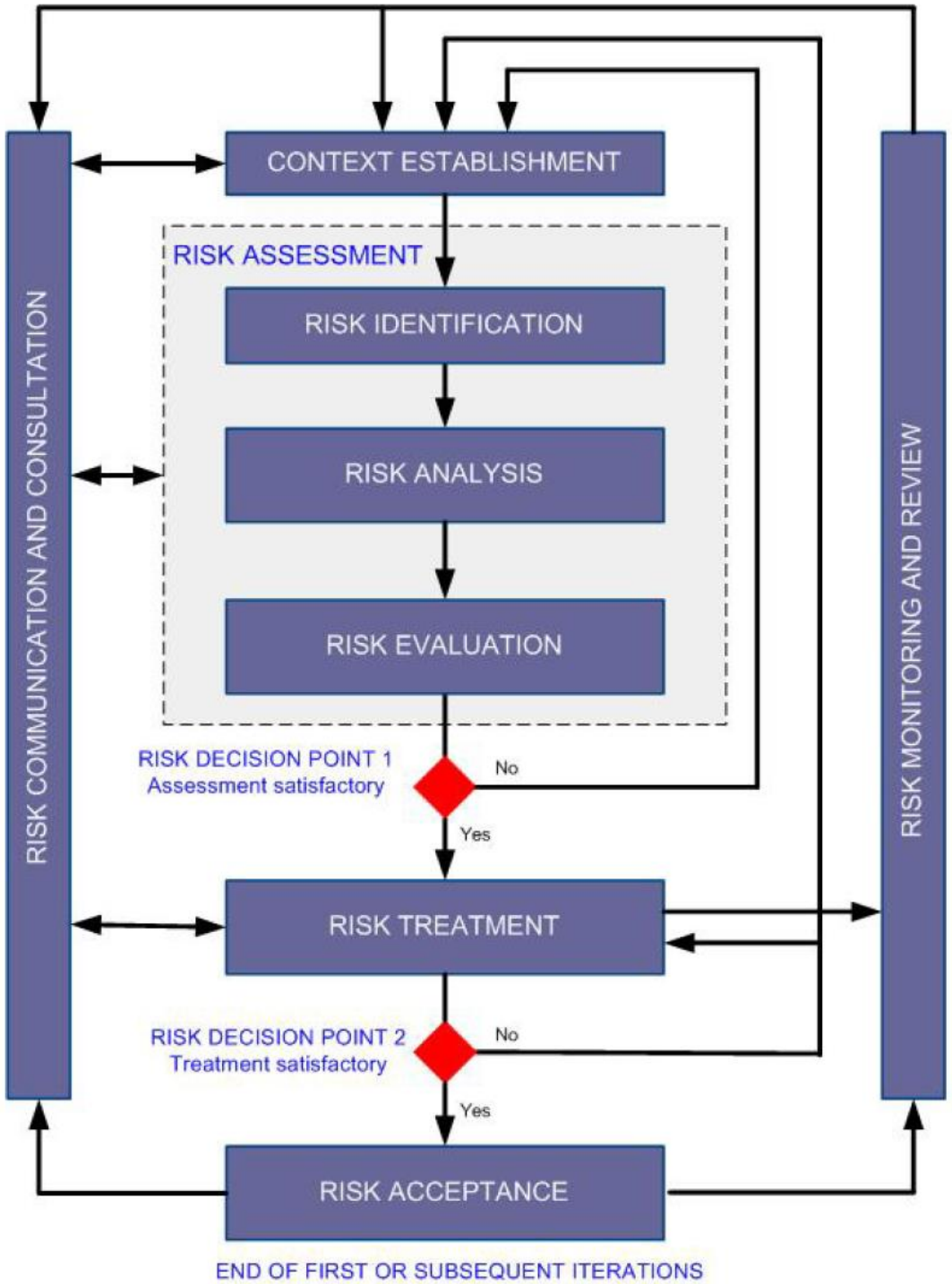
- Risk terminology is a bit problematic
- ISO/IEC 27005 is about Information Security Risk Management (ISRM)
  - Risk assessment
    - Risk identification
    - Risk analysis
    - Risk evaluation
- ISO 31000 is about (general) Risk Management (RM) (principles and guidelines)
- Processes are different between standards, best practices…



Terms according to ISO 27000

- Risk - effect of uncertainty on objectives
  - Note 1 to entry: An effect is a deviation from the expected — positive or negative.
  - Note 2 to entry: Uncertainty is the state, even partial, of deficiency of information related to, understanding or knowledge of, an event (2.25), its consequence (2.14), or likelihood (2.45).
  - Note 3 to entry: Risk is often characterized by reference to potential events (2.25) and consequences (2.14), or a combination of these.
  - Note 4 to entry: Risk is often expressed in terms of a combination of the consequences (2.14) of an event (including changes in circumstances) and the associated likelihood (2.45) of occurrence.
- Risk management - coordinated activities to direct and control an organization with regard to risk
- Risk management process - systematic application of management policies, procedures and practices to the activities of communicating, consulting, establishing the context and identifying, analysing, evaluating, treating, monitoring and reviewing risk
- Risk assessment - overall process of risk identification, risk analysis and risk evaluation
- Risk identification - process of finding, recognizing and describing risks
- Risk analysis - process to comprehend the nature of risk and to determine the level of risk
- Risk evaluation - process of comparing the results of risk analysis with risk criteria to determine whether the risk and/or its magnitude is acceptable or tolerable
- Level of risk - magnitude of a risk expressed in terms of the combination of consequences and their likelihood
- Residual risk - risk remaining after risk treatment
- Risk treatment - process to modify risk
- Vulnerability - weakness of an asset or control that can be exploited by one or more threats
- Threat - potential cause of an unwanted incident, which may result in harm to a system or organization

ISRM



The ISO 27005 ISRM process

Risk analysis

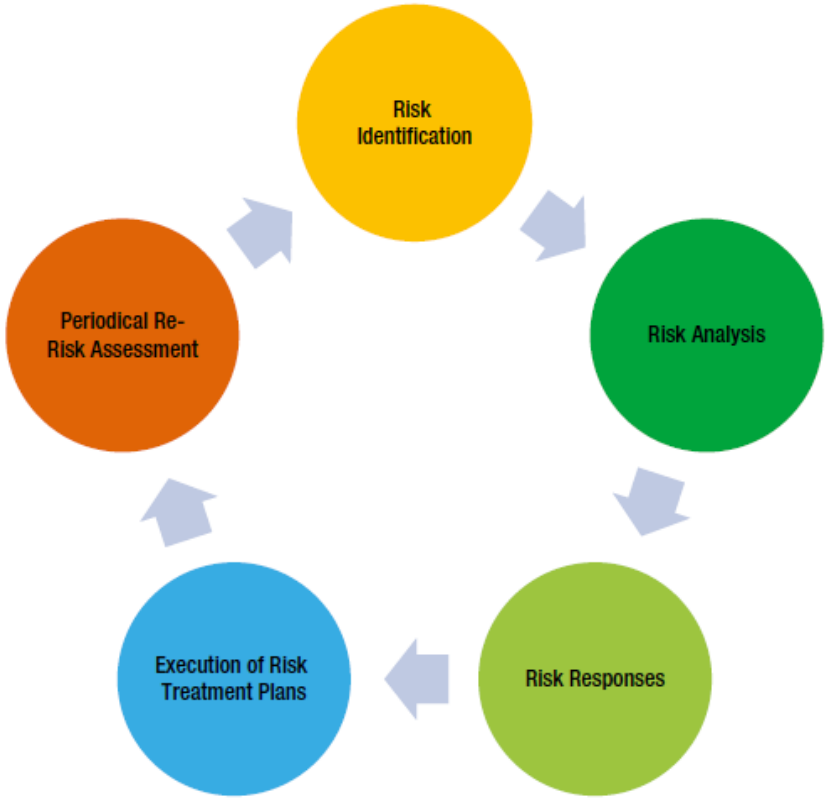
- ISO: the process to comprehend the nature of risk and to determine the level of risk
- A risk is a potential problem that the system or its users may experience
- Risk analysis is an organized process for identifying the most significant risks in a computing environment, determining the impact of those risks, and weighing the desirability of applying various controls against those risks
- Characteristics of a risk:
  - Associated loss (also known as a risk impact)
  - Likelihood of occurring
  - The degree to which we can change the outcome (risk control)
- We can theoretically quantify the effects of a risk, or risk exposure, by multiplying likelihood by risk impact
- Use risk leverage (difference in risk exposure divided by the cost of reducing the risk) to decide on if investments are worth or not

$$\frac{(\text{risk exposure before reduction}) - (\text{risk exposure after reduction})}{(\text{cost of risk reduction})}$$

Strategies for dealing with risk

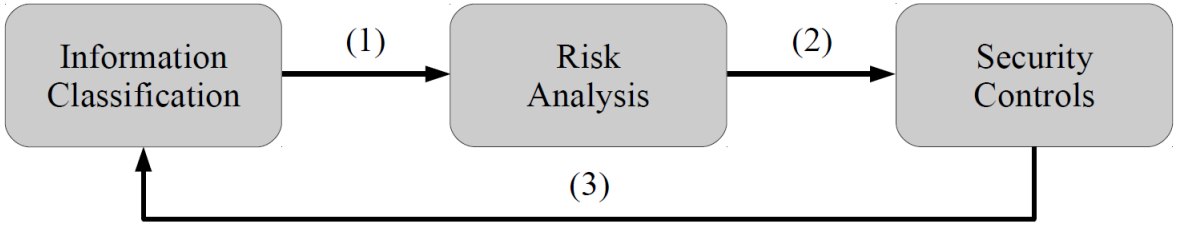
- Strategy:
  - *Avoid* the risk by changing requirements for security or other system characteristics
  - *Transfer* the risk by allocating the risk to other systems, people, organizations, or assets or by buying insurance to cover any financial loss should the risk become a reality
  - *Assume* the risk by accepting it, controlling it with available resources, and preparing to deal with the loss if it occurs
- Other strategies could be:
  - Avoid
  - Accept/retain/assume
  - Defend/remediation/limiting
  - Transfer/share
  - Control/mitigate/reduce
- No right/wrong, potential overlap…

Risk/ISRM processes



Rao (2014)

- A condensed ISRM process could be seen to include:
  - information classification/asset valuation, risk analysis and security controls



Lundgren & Bergström (2019)

Steps of a risk analysis

1. Identify assets
2. Determine vulnerabilities
3. Estimate the likelihood of exploitation
4. Compute expected annual loss
5. Survey applicable controls and their costs
6. Project annual savings of control

"Well he certainly does a very thorough risk analysis."

Step 1: Identify assets

- Information is valued according to a potential loss of CIA
- Information classification has been around for a long time in the military sector (top secret, secret and unclassified)
- Information classification can change over time
  - Over- and under-classification means over- or under-protected data
- "Everything" should be classified
  - Also intangibles such as reputation, people…
- Granularity of assets

Step 1: Identify assets

- Hardware: Processors, boards, keyboards, monitors, terminals, microcomputers, workstations, tape drives, printers, disks, disk drives, cables, connections, communications controllers, and communications media
- Software: Source programs, object programs, purchased programs, in-house programs, utility programs, operating systems, systems programs (such as compilers), and maintenance diagnostic programs
- Data: Data used during execution, stored data on various media, printed data, archival data, update logs, and audit records
- People: Skilled staff needed to run the computing system or specific programs, as well as support personnel such as guards
- Documentation: On programs, hardware, systems, administrative procedures, and the entire system
- Supplies: Paper, forms, laser cartridges, recordable media, and printer ink, as well as power, heating and cooling, and necessary buildings or shelter
- Reputation: Company image
- Availability: Ability to do business, ability to resume business rapidly and efficiently after an incident

Step 2: Determine vulnerabilities

- Example of a matrix mapping vulnerability to assets
- In practice, much longer
  - But depends on the granularity of assets
- Numerous vulnerability types can apply broadly to a class of assets
- For each cell, ask some helpful questions:
  - What are the effects of unintentional errors? Consider typing the wrong command, entering the wrong data, using the wrong data item, discarding the wrong listing, and disposing of output insecurely.
  - What are the effects of willfully malicious insiders? Consider disgruntled employees, bribery, and curious browsers.
  - What are the effects of outsiders? Consider network access, remote access, hackers, people walking through the building, people snooping at coffee shops, and people sifting through the trash.
  - What are the effects of natural and physical disasters? Consider fires, storms, floods, power outages, and component failures.
- Pre-compiled lists of common vulnerabilities exist and can work as a starting point

Asset	Secrecy	Integrity	Availability
Hardware		overloaded destroyed tampered with	failed stolen destroyed unavailable
Software	stolen copied pirated	impaired by Trojan horse modified tampered with	deleted misplaced usage expired
Data	disclosed accessed by outsider inferred	damaged - software error - hardware error - user error	deleted misplaced destroyed
People			quit retired terminated on vacation
Documentation			lost stolen destroyed
Supplies			lost stolen damaged

Step 3: Estimate the likelihood of exploitation

- Because it is impossible to know all vulnerabilities or all the ways those vulnerabilities can be exploited, it is also impossible to accurately assess the likelihood of exploitation!
- Possible approaches to estimation:
  - Apply frequency probability using observed data for a similar system
  - Use an analyst familiar with such systems to estimate the number of occurrences in a given time
  - Use descriptive adjectives or a simple rating system
  - Use an established approach such as Delphi
- Qualitative or quantitative approach → but both lead to a quantification
- Remember, there are many methods, formulas,…

Step 4: Compute expected loss

- There are obvious costs, e.g., hardware, software…
- There are also hidden costs:
  - Cost of restoring the system to a previous state
  - Cost of downtime
  - Legal fees
  - Loss of reputation and confidence
  - Loss of confidentiality
- Some hidden costs may be impossible to evaluate accurately, but still important to consider!

Step 5: Survey and select new controls

- Now you know:
  - Your assets
  - Vulnerabilities
  - Estimated likelihood of exploitation
  - Cost of exploitation/expected loss
- Time to select security controls!
- Each vulnerability may have one or more controls associated with it
- Each control may work for many assets and multiple vulnerabilities
- One approach is to use graph theory to select a minimal set of controls to address all vulnerabilities

Step 6: Project costs and savings

- The last step is to determine whether the costs of implementing controls outweigh the expected benefits
- The effective cost of a given control is the actual cost of the control
  - including purchase price, installation and deployment costs, and training costs
  - minus the expected loss the control is expected to prevent
- The cost may be positive if the product is very expensive or introduces new risks to the system
- Cost may be negative if the expected reduction in risk is greater than the cost of the control

Risk matrix

- EXTREME - 15 and above
- HIGH - 8 to 12
- MODERATE - 4 to 6
- LOW - 1 to 3

The purpose of the risk assessment matrix is to determine which risks can be accepted and which need to be managed.

		CONSEQUENCE				
		Negligible 1	Minor 2	Moderate 3	Major 4	Catastrophic 5
LIKELIHOOD	5 Almost certain	Moderate 5	High 10	Extreme 15	Extreme 20	Extreme 25
	4 Likely	Moderate 4	High 8	High 12	Extreme 16	Extreme 20
	3 Possible	Low 3	Moderate 6	High 9	High 12	Extreme 15
	2 Unlikely	Low 2	Moderate 4	Moderate 6	High 8	High 10
	1 Rare	Low 1	Low 2	Low 3	Moderate 4	Moderate 5

Pros and cons with risk analysis

- Pros
  - Improve awareness
  - Relate security mission to management objectives
  - Identify assets, vulnerabilities, and controls
  - Improve basis for decisions
  - Justify expenditures for security
- Cons
  - False sense of precision and confidence
  - Hard to perform
  - Have a tendency to be filed and promptly forgotten
  - Lack of accuracy

What's the alternative?

More background

- Focus on the organization
- There should be a plan for information security
- There is no one-process-fit-all!
- The ISO 27000 family is an alternative – but not the only alternative (e.g., COBIT, NIST…)
- ISO (and others help) to structure e.g.,:
  - Who is responsible, and for what? E.g., asset ownership, system ownership, risk,…
  - What is the role of the management from an infosec perspective
  - Help systematize the continual improvement
  - Aid in evaluation

Management systems

- A management system is a *"set of interrelated or interacting elements of an organization to establish policies and objectives and processes to achieve those objectives"* (ISO/IEC 27000:2014)
- We already use management systems in other areas such as:
  - Quality Management System - ISO 9000
  - Environmental Management System - ISO 14000
  - IT Service Management System - ISO 20000
- So why not do the same for infosec?
  - Information Security Management System - ISO 27000

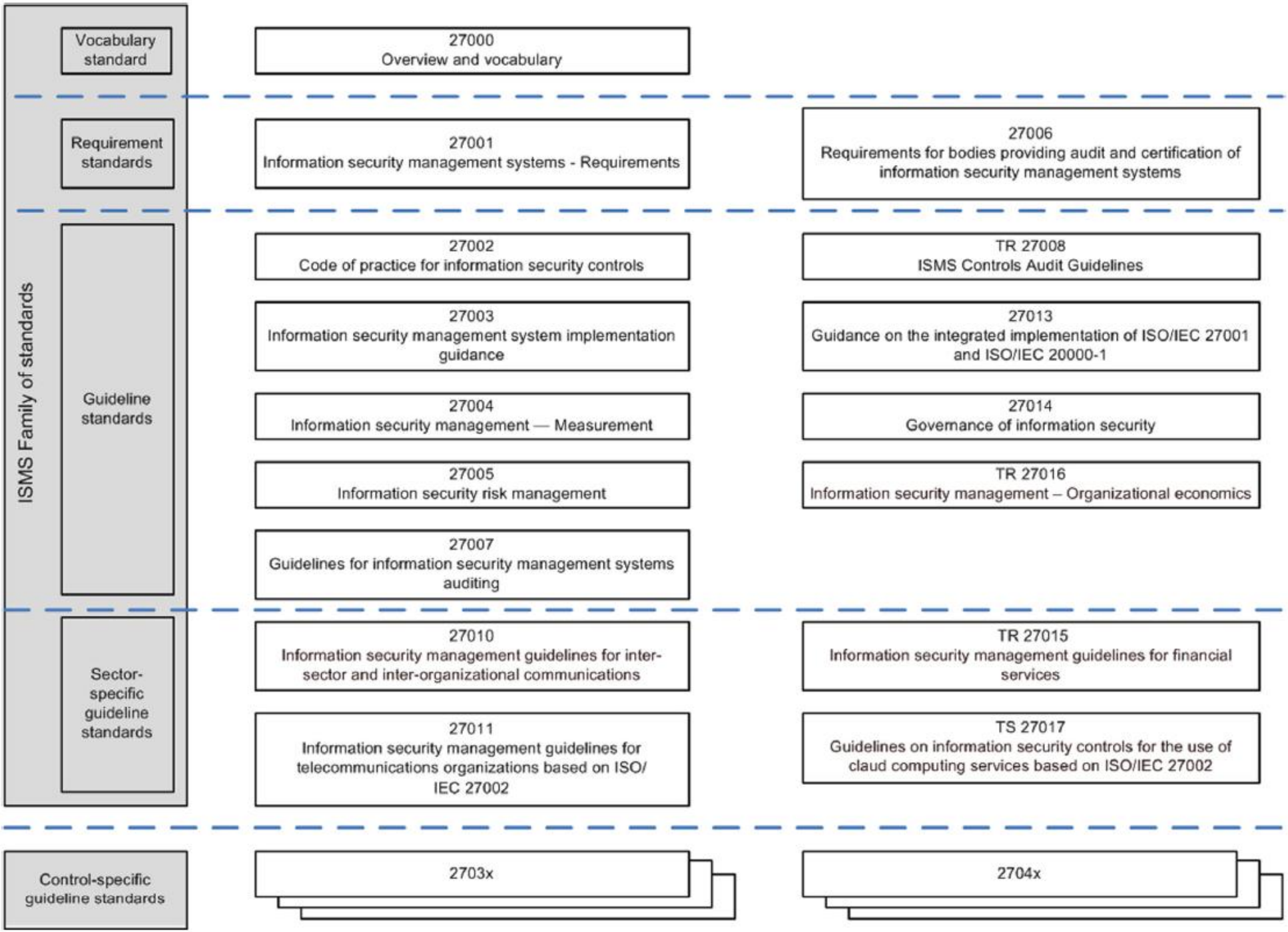
Information Security Management Systems is defined as *"that part of the overall management system, based on a business risk approach, to establish, implement, operate, monitor, review, maintain and improve information security"* (ISO/IEC 27001:2005, 2005 p. 2)

ISMS according to ISO 27000

- *An Information Security Management System (ISMS) consists of the policies, procedures, guidelines, and associated resources and activities, collectively managed by an organization, in the pursuit of protecting its information assets.*
- *An ISMS is a systematic approach for establishing, implementing, operating, monitoring, reviewing, maintaining and improving an organization's information security to achieve business objectives.*
- *It is based upon a risk assessment and the organization's risk acceptance levels designed to effectively treat and manage risks.*
- *Analysing requirements for the protection of information assets and applying appropriate controls to ensure the protection of these information assets, as required, contributes to the successful implementation of an ISMS.*

ISO 27000 family

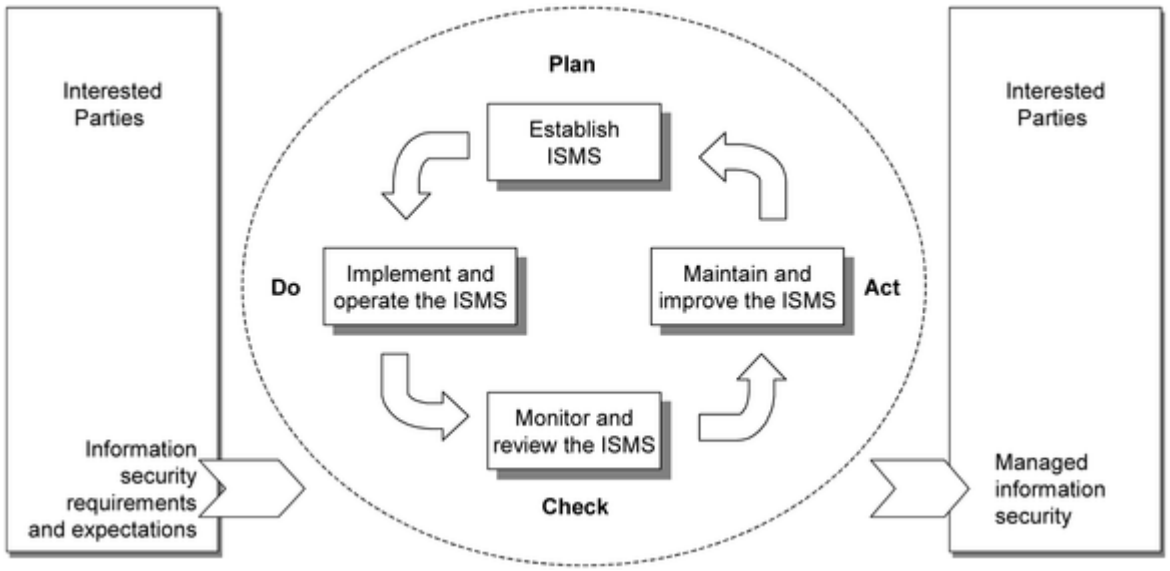
- We need help on different levels
  - Aiding the general aspects of the implementation
  - General about controls
  - Specifics about the controls
  - Sector-specific recommendations
  - How to do risk analysis/assessment/management
- So we need many standards!
- Standards tell what to do, but not necessarily how!



ISO 27000 family of standards relationships

(From ISO 27000)

PDCA/continual improvement



ISO 27001:2005

- Also known as the Demming Cycle
- Used when:
  - Starting from scratch, or when
  - Improving or when, or when
  - Performing a task

Also, on different levels

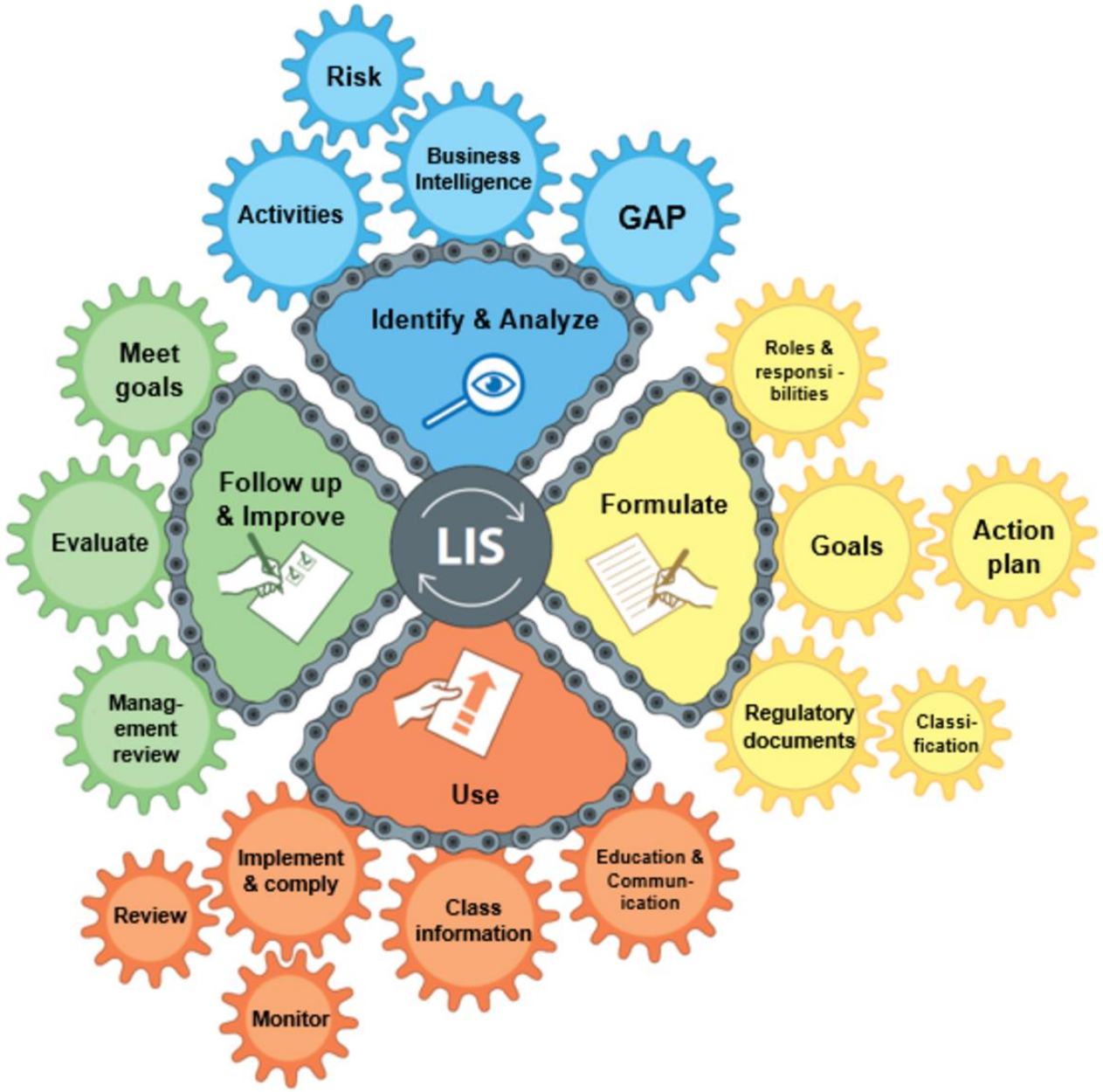
Strategic – Organization as a whole, policy, long-term…

Tactical – Implements the decisions…

Operational – Day-to-day operations…

Where do we start?

- Many activities to perform
- Hard to get overall understanding/support



Where do we start?
More or less according to MSB/best practice…

- We have so many assets
- What are the most valuable assets?
  - Initial subjective classification
- Make an organizational-wide risk analysis
- GAP analysis
- Controls
- Next classification
- (GAP/risk)
- Controls
- Next classification…

Dealing with disaster and human vandals

- Natural disasters:
  - Flood
  - Fire
  - Earthquake
- Mitigations:
  - Develop contingency plans so that people know how to react in emergencies and business can continue
  - Insure physical assets—computers, buildings, devices, supplies—against harm
  - Preserve sensitive data by maintaining copies in physically separated locations
  - Prevent power loss using Uninterruptable Power Supplies (UPS) and surge suppressors
- Also need to mitigate unauthorized access, use, and theft:
  - Guards, fences, security doors, tight access control…

Fire

Power outages

Interception of sensitive information

- Mitigations:
  - Shred paper copies of sensitive information
  - Overwrite magnetic data (several times) using software designed for that purpose
  - Degauss magnetic media (a demagnetizing process)
  - Protect against RF emanation by trapping signals or adding spurious ones
    - Mainly critical to society but secure meeting rooms etc. getting more common for larger organizations

Contingency planning

- Backups
  - Offsite backup
  - Cloud backup
- Failover
  - Cold site – prepared backup location, spare machines… ~24 to uptime
  - Hot site – like cold but more prepared, can also be shared/rented

JÖNKÖPING UNIVERSITY

School of Engineering